

**UCSC****University of Colombo, Sri Lanka***University of Colombo School of Computing***DEGREE OF BACHELOR OF INFORMATION TECHNOLOGY
(EXTERNAL)**Academic Year 2023 — 3rd Year Examination — Semester 6**IT6406 — Network Security and Audit***Structured Question Paper*
(2 Hours)**To be completed by the candidate****Index Number**

--	--	--	--	--	--	--

Important Instructions

- The duration of the paper is **2 hours**.
- The medium of instructions and questions is English. Students should answer in the medium of English language only.
- This paper has **4 questions** on **11 pages**. Answer **all** questions.
- All questions carry **equal** marks.
- Write your answers **only on the space provided** on this question paper.
- Do not tear off any part of this question paper. Under no circumstances may this paper (or any part of this paper), used or unused, be removed from the Examination Hall by a candidate.
- Note that questions appear on both sides of the paper. If a page or part of a page is not printed, please inform the supervisor/invigilator immediately.
- Any electronic device capable of storing and retrieving text, including electronic dictionaries, smartwatches, and mobile phones, is not allowed.
- Calculators are **allowed**.
- *All Rights Reserved*. This question paper can NOT be used without proper permission from the University of Colombo School of Computing.

**To be completed by
the examiners**

1	
2	
3	
4	
Total	

Index Number

--	--	--	--	--	--	--

1. (a). **Accidental association** is one of the security threats in wireless networks. List down **four (4)** other security threats.

[4 marks]

Malicious association, Ad hoc networks, Nontraditional networks, Identity theft (MAC spoofing), Man-in-the middle attacks, Denial of service (DoS), Network injection, Topic 7 Teachers note page 4

- (b). Briefly explain how the **accidental association** of a wireless networks becomes a security threat.

[6 marks]

Company wireless LANs or wireless access points to wired LANs in close proximity (e.g., in the same or neighboring buildings) may create overlapping transmission ranges. A user intending to connect to one LAN may unintentionally lock on to a wireless access point from a neighboring network. Although the security breach is accidental, it nevertheless exposes resources of one LAN to the accidental user. Topic 7 Teachers note page 4

- (c). Mention **two (2)** security measures that can be used to reduce threats to wireless networks.

[4 marks]

turning off service set identifier (SSID) broadcasting, reducing signal strength to the lowest level that still provides requisite coverage, Encryption of all wireless transmission, securing wireless access points, Topic 7 Teachers note page 5

Index Number

--	--	--	--	--	--	--

(d). List down **two (2)** types of firewalls.

[2 marks]

Packet Filtering Firewall, Stateful Inspection Firewalls, Application-Level Gateway, Circuit-Level Gateway, Topic 5 Teachers note page 6

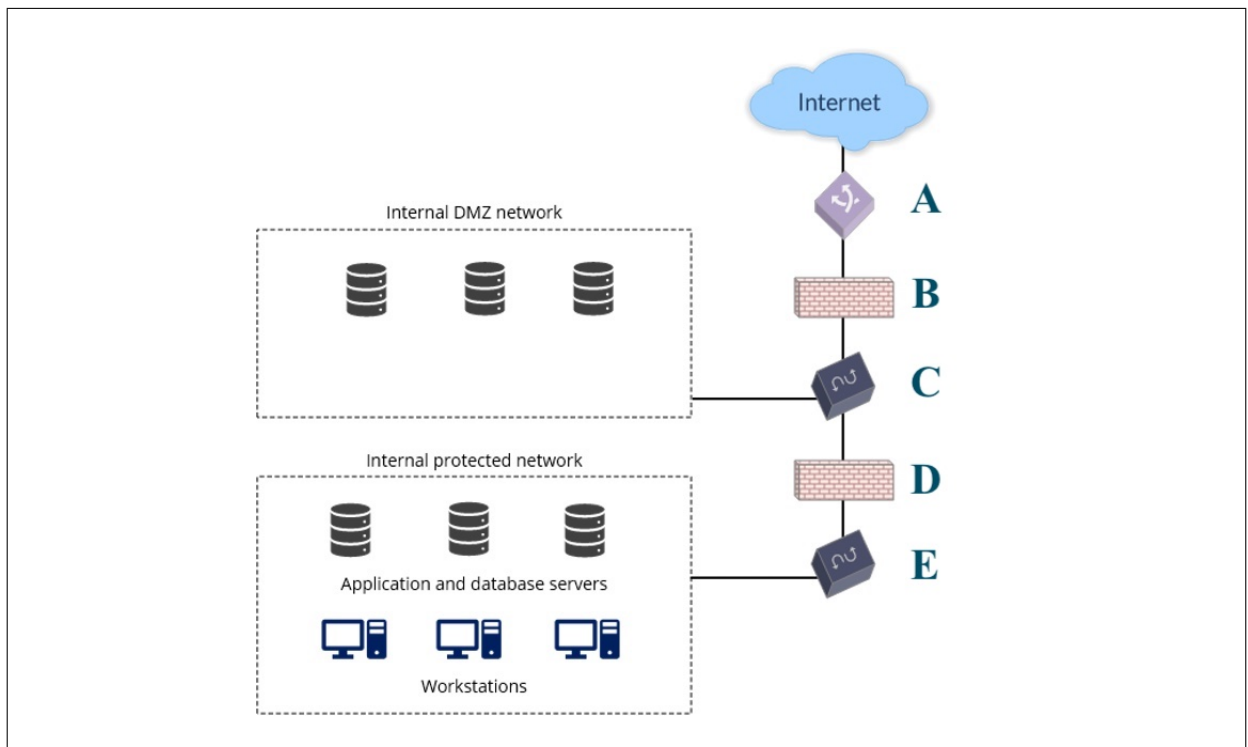
(e). Briefly describe the **Bastion host** in a demilitarised zone of the network.

[4 marks]

A bastion host is a system identified by the firewall administrator as a critical strong point in the network's security. The bastion host serves as a platform for an application-level or circuit-level gateway. Topic 5 Teachers note page 7

(f). Using a suitable diagram, illustrate the network deployment of a **demilitarized zone** and its connectivity to both **Internet** and **internal networks**.

[5 marks]



Index Number

--	--	--	--	--	--	--

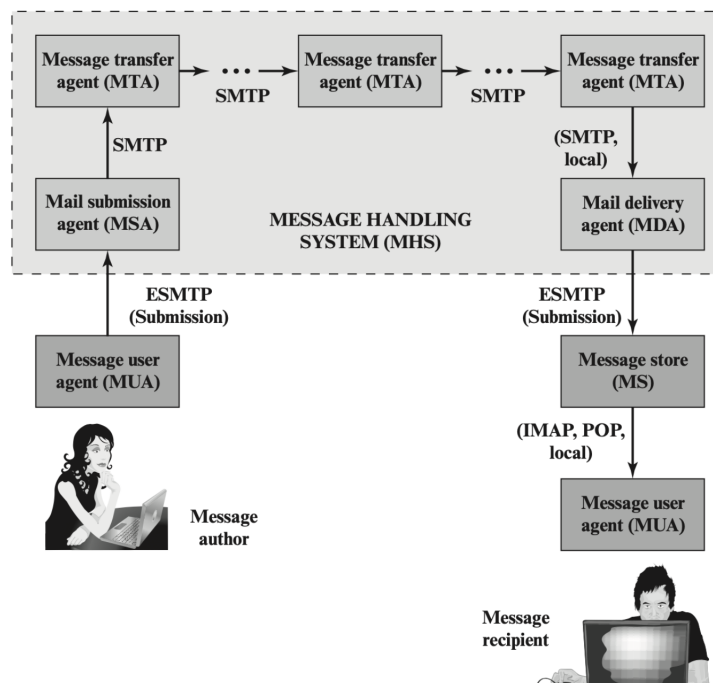
2. (a). List down the **five (5)** main components of the **Email architecture**.

[5 marks]

Message User Agent (MUA), Mail Submission Agent (MSA), Message Transfer Agent (MTA), Mail Delivery Agent (MDA), Message Store (MS), Topic 6 Teachers note page 3

- (b). Using a suitable diagram, illustrate the flow of an email that moves through the **components of the email architecture** from the author to the recipient.

[8 marks]



Index Number

--	--	--	--	--	--	--

- (c). Content modification during transit is a common threat on emails. As a result, this might leak sensitive information to wrong hands and an altered message will be received by the receiver. Propose a mitigation strategy for above mentioned situation.

[5 marks]

Use of TLS to encrypt email transfer between servers. Use of end-to-end email encryption. Topic 6 Teachers note page 8

- (d). IT infrastructure can be categorised into seven (7) domains. User domain is one of them. List any **three (3)** other domains.

[3 marks]

Workstation Domain, LAN Domain, LAN-to-WAN Domain, WAN Domain, Remote Access Domain, System/Application Domain. Topic 10 Teachers note page 5

- (e). Explain the **User domain** of IT infrastructure.

[4 marks]

The end users of the systems, including how they authenticate into the systems. Topic 10 Teachers note page 5

--	--	--	--	--	--	--

3. (a). Use the authentication protocol given below to answer the questions.

$C \Rightarrow AS : ID_C || P_C || ID_V$

$AS \Rightarrow C : Ticket$

$C \Rightarrow V : ID_C || Ticket$

where:

$C = client$

$AS = Authentication Server$

$V = User requested service. e.g. FTP$

$E = Denotes encryption$

$ID_C = Identifier of user on C$

$ID_V = Identifier of V$

$P_C = Password of user on C$

$K_V = Secret encryption key shared by AS and V$

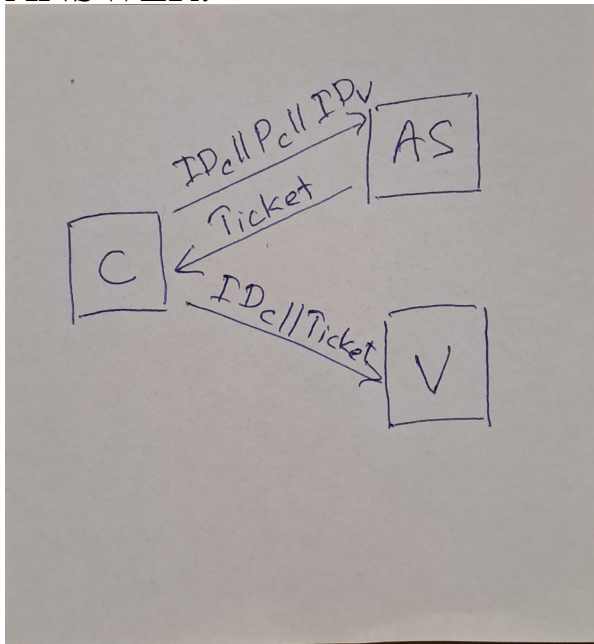
$AD_C = Network address of C$

$Ticket = E(K_V, [ID_C || AD_C || ID_V])$

- i. Draw a diagram to illustrate the protocol. Write the message content on top of the directional arrows in your diagram.

[4 marks]

ANSWER:



--	--	--	--	--	--	--

ii. List **three (03)** security issues of the given protocol.

[6 marks]

ANSWER: Teacher's note: Slide 21

- we would like to minimize the number of times that a user has to enter a password
- An eavesdropper could capture the password and use any service accessible to the victim
- Using the ticket to conduct replay attacks.

(b). IP Security is a protocol that can be used to implement Virtual Private Networks (VPNs).

- i. What are the **two (02)** protocols defined under IP Security? Briefly describe each of those protocols using a single sentence.

[6 marks]

ANSWER: Teacher's note slide 18

Authentication Header (AH) - an authentication protocol designated by the header of the protocol

Encapsulating Security Payload (ESP) - a combined encryption/authentication protocol designated by the format of the packet for that protocol

Index Number

--	--	--	--	--	--	--

ii. List **four (04)** security services provided by IP Security.

[4 marks]

ANSWER: Teacher's note slide 19

Access control, Connectionless integrity, Data origin authentication, Rejection of replayed packets (a form of partial sequence integrity), Confidentiality (encryption), Limited traffic flow confidentiality

(c). Security attacks can be classified into two groups as **passive attacks** and **active attacks**. Write **two (02)** examples for each group.

[5 marks]

ANSWER: Teacher's note 10 and 11

Passive - eavesdropping on, or monitoring of transmissions

Active - Masquerade, Replay, Modification of messages, Denial of service

Index Number

--	--	--	--	--	--	--

4. (a). Transport Layer Security (TLS) is not a single protocol but rather two layers of protocols above TCP.
- i. Write the **four (04)** phases of TLS Handshake protocol.

[4 marks]

ANSWER: Teacher's note: Slide 21
Establish security capabilities
Server authentication and key exchange
Client authentication and key exchange
Finish

- ii. Write **three (03)** key exchange methods that are supported by the Phase I of TLS Handshake protocol.

[4 marks]

ANSWER: Teacher's note: Slide 25
RSA, Fixed Diffie–Hellman, Ephemeral Diffie–Hellman, Anonymous Diffie–Hellman.

Index Number

--	--	--	--	--	--	--

iii. Write the currently recommended version of TLS protocol.

[2 marks]

ANSWER: Teacher's note: Slide 38
1.3

(b). Write **two (02)** techniques used in statistical anomaly based intrusion detection and explain how each technique detects intrusions.

[8 marks]

ANSWER: Teacher's note: Slide 12

Threshold detection: This approach involves defining thresholds, independent of user, for the frequency of occurrence of various events.

Profile based: A profile of the activity of each user is developed and used to detect changes in the behaviour of individual accounts.

Index Number

--	--	--	--	--	--	--

- (c). **Information Technology Security Assessment** is crucial for systems security compliance. To understand the current state of compliance, organizations must assess their security controls. List **four (04)** activities relating to security controls improvement which need the information provided by a security assessment.

[7 marks]

ANSWER: Teacher's note: Slide 9

Identify weaknesses within the controls implemented on information systems

Confirm that previously identified weaknesses have been remediated or mitigated

Prioritize further decisions to mitigate risks

Provide assurance, a level of confidence that effective controls are in place and that associated risks are accepted and authorized.

Provide support and planning for future budgetary requirements.
